The Client: The Grand Marina, a large hotel with three HYDROLOGIC water-monitoring devices deployed across the Main Building, Pool/Spa Wing, and Kitchen/Laundry areas.

The Situation: After completing the threat model, I was asked to design the MQTT topic structure for The Grand Marina's water monitoring system. This structure will determine how water pressure and flow readings are transmitted, how alerts are reported when problems are detected, and how commands reach the HYDROLOGIC devices when operators need to take action.

Topic 1: Hierarchy

```
hydroficient/
└── grandmarina/
    ├── sensors/
    │      ├──main-building/
    │      │          ├── pressure-upstream
    │      │          ├── pressure-downstream
    │      │          └── flow-rate
    │      │
    │      ├──pool-spa-wing/
    │      │        ├──pressure-upstream
    │      │        ├──pressure-downstream
    │      │        └──flow-rate
    │      │
    │      └──kitchen-laundry/
    │                ├── pressure-upstream
    │                ├── pressure-downstream
    │                └── flow-rate
    │
    │
    ├── commands/
    │        ├── main-building/
    │        │          ├── emergency-shutoff
    │        │          └── gate-adjustment
    │        │
    │        ├──pool-spa-wing/
    │        │          ├── emergency-shutoff
    │        │          └── gate-adjustement
    │        │
    │        └──kitchen-laundry/
    │                   ├── emergency-shutoff
    │                   └── gate-adjustment
    │
    │
    ├── alerts/
    │        ├── main-building/
```

```
│         │       ├── leak-detected
│         │       ├── pressure-anomaly
│         │       └── flow-anamoly
│         │
│         ├── pool-spa-wing/
│         │        ├── leak-detected
│         │        ├── pressure-anomaly
│         │        └── flow-anomaly
│         └── kitchen-laundry/
│                   ├── leak-detected
│                   ├── pressure-anomaly
│                   └── flow-anomaly
└── status/
          ├── main-building/
          │         ├── heartbeat
          │         └── connection
          │
          ├──pool-spa-wing/
          │         ├── heartbeat
          │         └── connection
          │
          └──kitchen-laundry/
                     ├── heartbeat
                     └──connection
```

Design Notes

I organized the MQTT topics by the three HYDROLOGIC device locations: Main Building, Pool/Spa Wing, and Kitchen/Laundry. Each location has separate topics for sensor readings, commands, alerts, and status information. This makes it easier for operators to monitor a specific area without subscribing to the entire system.

Sensor topics contain upstream pressure, downstream pressure, and flow-rate readings, which are published every 5 seconds. Commands are separated by location and include emergency shutoff and gate adjustment operations. Alerts include leak detection, pressure anomalies, and flow anomalies. Status topics provide device heartbeat information every 30 seconds and connection status updates.

This structure also makes MQTT subscriptions more flexible. For example, an operator responsible for the Pool/Spa Wing could subscribe to `hydroficient/grandmarina/sensors/pool-spa-wing/#` to receive all sensor readings from that area.

Part 2: Security Reflection

1. What happens if someone subscribes to hydroficient/grandmarina/#?

The # wildcard matches every topic underneath hydroficient/grandmarina/. Therefore, someone who subscribes to this topic could see all sensor readings, alerts, commands, heartbeats, and connection-status information from all three HYDROLOGIC devices.

This access should be limited to authorized operators and administrators. An unauthorized subscriber could gain a complete real-time view of the hotel's water infrastructure and operations.

2. What sensitive information could they see?

An unauthorized user could potentially see:

- **Water usage patterns:** Pressure and flow readings could reveal when different areas of the hotel are busy or inactive.
- **Pool and spa activity:** Changes in flow and pressure could indicate when the pool, spa, or fitness facilities are being used.
- **Kitchen and laundry operations:** Flow patterns could reveal restaurant, housekeeping, and laundry activity.
- **Physical locations:** Topic names identify important areas of the hotel and the location of each HYDROLOGIC device.
- **Operational patterns:** Timestamps and repeated sensor readings could reveal daily schedules and periods of high or low activity.
- **Infrastructure problems:** Alerts could reveal leaks, abnormal pressure, or abnormal water flow.
- **Device availability:** Heartbeat and connection information could show when a device is offline or experiencing problems.

3. What actions could they take if they could also publish to command topics?

If an attacker could publish to command topics without proper authentication and authorization, they could potentially:

- **Trigger an emergency shutoff:** This could stop water service to a hotel area and disrupt guests, staff, or critical operations.
- **Adjust water gates:** Unauthorized gate adjustments could change water pressure or flow and potentially cause operational problems.

- **Disrupt hotel services:** Attacks against the Pool/Spa Wing could affect pool and spa operations, while attacks against the Kitchen/Laundry area could interfere with restaurants and housekeeping.
- **Cause physical or financial damage:** Repeated or malicious commands could waste water, interrupt operations, or potentially damage equipment.

Because command topics can control physical infrastructure, they should have strict access controls. Only authorized operators should be allowed to publish to command topics, and MQTT authentication, authorization/ACLs, TLS, and message validation should be used to protect the system.